

SIMATS ENGINEERING

ITA1407 ETHICAL HACKING – CO5-AT1

PRIYA DHARSHINI M (192521051)

Course Outcome Covered

CO5: Analyze vulnerabilities in Windows and Linux systems and evaluate security weaknesses in messaging, web, and mobile applications using appropriate exploitation techniques and hacking tools. **(BT5)**

Question 1

Given Data

- Total systems = 150
- Systems allowing anonymous enumeration = 45%
- Among these, systems susceptible to SMB lateral movement = 60%
- Each compromised system attempts to access 3 additional systems
- Success probability per attempt = 0.3
- Large-scale compromise threshold = greater than 70%

Step 1: Calculate systems vulnerable to anonymous enumeration

$$[150 \times 45\% = 67.5]$$

Approximately:

$$[68]$$

Therefore, about **68 systems** are exposed to anonymous enumeration.

Step 2: Calculate initially compromised systems

60% of the 68 systems are susceptible to SMB-based lateral movement:

$$[68 \times 60\% = 40.8]$$

Approximately:

$$[41]$$

Thus, the estimated initial compromise is **41 systems**.

Step 3: Calculate second-stage lateral movement

Each compromised system can attempt 3 additional systems.

Total attempts:

$$[41 \times 3 = 123]$$

With a success probability of 0.3:

$$[123 \times 0.3 = 36.9]$$

Therefore, approximately:

$$[37]$$

Step 4: Estimate total compromised systems

$$[41 + 37 = 78]$$

Thus, the estimated number of compromised systems after the second stage is:

$$[78]$$

Step 5: Determine whether the network faces large-scale compromise

70% of the network is:

$$[150 \times 0.7 = 105]$$

The estimated compromise is 78 systems.

$$[78 < 105]$$

Percentage compromised:

$$[\frac{78}{150} = 52\%]$$

Therefore:

$$[52\%]$$

The estimated compromise is **52%**, which is below the 70% large-scale compromise threshold.

Evaluation

Although the estimated result does not exceed 70%, the situation is still **high risk** because more than half of the network could potentially become compromised through lateral movement.

The vulnerability that should receive the highest priority is **misconfigured shared folders/weak SMB shares**, because they directly facilitate lateral movement after an attacker obtains initial access.

Recommended Mitigation

1. Disable unnecessary NULL sessions and anonymous enumeration.
2. Restrict SMB access using firewall and network segmentation.
3. Correct weak shared-folder permissions.
4. Apply least-privilege access.
5. Disable unnecessary RPC services.
6. Monitor SMB authentication and lateral movement activity.

Final Answer

[]

[]

[]

[]

The network is **not yet above the 70% large-scale compromise threshold**, but it is at significant risk. **Weak shared folders/SMB configuration should be prioritized** because they enable rapid lateral movement.

Question 2

Given Data

- Total systems = 120
- Systems exposing RPC = 70
- 40% of RPC-exposed systems are vulnerable
- Successful exploitation probability = 0.5
- Detection probability per attempt = 0.25

Step 1: Determine vulnerable systems

[70 = 28]

Therefore:

[]

Step 2: Calculate expected successful compromises

Each vulnerable system has a 0.5 probability of successful exploitation.

[28 = 14]

Therefore:

[]

are expected to be successfully compromised.

Step 3: Calculate expected detection alerts

Detection probability = 0.25.

[28 = 7]

Therefore:

[]

are expected.

Step 4: Evaluate stealthiness

The attacker has an expected:

- 14 successful compromises
- 7 detection alerts

The probability of detection for each attempt is significant at **25%**. Therefore, a large number of exploitation attempts creates a substantial chance that defensive monitoring will identify the activity.

The attacker seeking to remain stealthy would therefore have an incentive to avoid noisy exploitation of all vulnerable RPC systems and may instead seek quieter attack paths, such as compromising credentials or exploiting already exposed services.

From the defender's perspective, the RPC exposure should be reduced because unnecessary RPC services increase the attack surface.

Final Answer

[]

[]

[]

The **25% detection probability** represents a meaningful detection risk. A stealth-focused attacker would therefore be less likely to repeatedly exploit RPC services and may attempt to find a lower-noise entry point.

Question 3

Given Data

Four internet-facing services have independent vulnerability probabilities:

[$P_1=0.3$]

[$P_2=0.2$]

[$P_3=0.25$]

[$P_4=0.15$]

Probability of privilege escalation through weak file permissions:

[$P_E=0.5$]

Step 1: Calculate probability that no service is vulnerable

The probability that each service is not vulnerable is:

[$1-0.3=0.7$]

[$1-0.2=0.8$]

[$1-0.25=0.75$]

[$1-0.15=0.85$]

Therefore:

[$P()=0.7$]

[$=0.357$]

Step 2: Calculate probability that at least one service is vulnerable

[$P()=1-P()$]

[$=1-0.357$]

[=0.643]

Therefore:

[]

There is a **64.3% probability that at least one exposed service is vulnerable.**

Step 3: Calculate probability of full system compromise

Assuming that exploitation of at least one vulnerable service provides initial access and that weak permissions can then be exploited with probability 0.5:

[P() =0.643]

[=0.3215]

Therefore:

[]

Step 4: Evaluate file-permission mitigation

Weak file permissions contribute to the final privilege-escalation stage. If they are completely corrected, the specific escalation probability through this route becomes zero.

However, strengthening permissions alone does **not** eliminate the initial attack risk because the probability of at least one vulnerable service remains:

[]

Thus, attackers could still gain initial access through vulnerable internet-facing services even if privilege escalation becomes more difficult.

Recommended Mitigation

The organization should:

1. Patch vulnerable internet-facing services.
2. Remove unnecessary public-facing services.
3. Use firewalls and access controls.
4. Correct weak file permissions.
5. Apply least privilege.
6. Monitor exposed services for suspicious activity.

Final Answer

[]

[]

Strengthening file permissions is important, but **it should not be the only mitigation**. Internet-facing vulnerable services must also be patched and restricted.

Question 4

Given Data

Three subnets have unauthorized-access probabilities:

[$P_1=0.4$]

[$P_2=0.3$]

[$P_3=0.2$]

Probability of privilege escalation to root after obtaining NFS access:

[$P_R=0.7$]

Step 1: Calculate probability that none of the subnets gains unauthorized access

[$P()=(1-0.4)(1-0.3)(1-0.2)$]

[$=0.6$]

[$=0.336$]

Step 2: Calculate probability that at least one subnet gains access

[$P()=1-P()$]

[$=1-0.336$]

[$=0.664$]

Therefore:

[]

There is a **66.4% probability of unauthorized access to the NFS share**.

Step 3: Calculate overall probability of complete compromise

Once unauthorized access is obtained, root privilege escalation has probability 0.7.

Therefore:

$$[P() = 0.664]$$

$$[= 0.4648]$$

Therefore:

$$[]$$

Step 4: Evaluate restricting NFS to a single subnet

Suppose NFS access is restricted to the safest subnet, which has an unauthorized-access probability of 0.2.

Then:

$$[P() = 0.2]$$

Complete compromise probability becomes:

$$[0.2 = 0.14]$$

Therefore:

$$[]$$

The probability falls from:

$$[46.48\%]$$

Reduction:

$$[46.48 - 14 = 32.48]$$

Relative reduction:

$$[\%]$$

Thus, restricting NFS to a single well-secured subnet can reduce the estimated complete-compromise probability by approximately **69.9%** relative to the original scenario.

Recommended Mitigation

The organization should:

1. Restrict NFS access to trusted subnets.
2. Use strong host-based access controls.
3. Disable unnecessary NFS exports.
4. Apply least-privilege permissions.
5. Monitor NFS authentication and access logs.
6. Prevent unnecessary root-level privileges.

Final Answer

[]

[]

If access is restricted to the subnet with probability 0.2:

[]

Therefore, **restricting NFS access to a single trusted subnet is an effective mitigation strategy**, particularly when combined with strong permissions and monitoring.

Question 5

Data Extraction and Breach Severity Analysis

To calculate the requested values, the question must provide at least:

- Total number of records in the database
- Number of records extracted per attack attempt, or extraction rate
- Number of attempts/time before the attack is blocked
- Percentage or number of records classified as sensitive

Step 1: Total records extracted

If:

- (R) = records extracted per attempt
- (N) = number of successful attempts before blocking

Then:

[]

Step 2: Percentage of total data compromised

If:

- (T) = total records stored
- (C) = total records extracted

Then:

[=]

Therefore:

[]

Step 3: Sensitive records exposed

If:

- (S) = percentage of extracted records that are sensitive

Then:

[= C]

Therefore:

[]

Step 4: Severity evaluation

The severity of a data breach depends on:

- Number of records exposed
- Percentage of the organization's total data compromised
- Number of sensitive records exposed
- Type of information exposed
- Duration before detection
- Ability of the attacker to continue extracting data

A breach involving a large percentage of the database or sensitive financial/customer information should be classified as **high or critical severity**.

Step 5: Evaluate the detection mechanism

If the attacker is able to extract a substantial number of records before being blocked, the existing detection mechanism is not sufficiently effective for protecting critical data.

A strong detection mechanism should:

1. Detect abnormal data-access patterns.
2. Monitor unusually large database queries.
3. Identify repeated extraction attempts.
4. Generate alerts quickly.
5. Automatically block suspicious activity.
6. Apply rate limiting.
7. Enforce least-privilege database access.
8. Maintain detailed audit logs.

Final Evaluation

Without the missing numerical values, an exact number and percentage cannot be calculated. However, the formulas are:

[]

[]

[]

If a significant number of sensitive records can be extracted before detection, the breach should be considered **high severity**, and the organization should strengthen real-time monitoring, access controls, anomaly detection, and automated blocking.

Overall Conclusion

The assessment demonstrates that vulnerabilities in Windows and Linux environments can create significant opportunities for unauthorized access and privilege escalation.

For the Windows domain in Question 1, approximately **41 systems could be initially compromised**, with an estimated **37 additional systems affected through second-stage lateral movement**, giving approximately **78 potentially compromised systems**.

For the RPC scenario in Question 2, approximately **14 systems are expected to be successfully compromised**, while approximately **7 detection alerts** may be generated.

For the Linux server in Question 3, there is a **64.3% probability of at least one vulnerable service** and an estimated **32.15% probability of full compromise** when weak permissions are considered.

For the NFS scenario in Question 4, the probability of unauthorized access is **66.4%**, while the estimated probability of complete compromise is **46.48%**. Restricting NFS access to the lowest-risk single subnet reduces the estimated complete-compromise probability to **14%**.

Overall, organizations should use a **defense-in-depth approach** involving patch management, network segmentation, least privilege, secure service configurations, access control, continuous monitoring, intrusion detection, and timely incident response.